



ANDROID STATIC ANALYSIS REPORT



 Mountain Project (22.31.0)

File Name: mountainproject.apk

Package Name: com.mountainproject.android

Scan Date: Jan. 31, 2023, 6:41 p.m.

App Security Score: 38/100 (HIGH RISK)

Grade:



Trackers Detection: 6/428

FINDINGS SEVERITY

 HIGH	 MEDIUM	 INFO	 SECURE	 HOTSPOT
5	9	1	1	1

FILE INFORMATION

File Name: mountainproject.apk

Size: 6.17MB

MD5: ebb12ed012df81f4dd3fad162fb4c2e5

SHA1: d8e4396969e11b41f63b3e479d47a654f25be439

SHA256: a7e168b15755204a53600feac968fa950ccbf247a063a2c94db3361442c39557

APP INFORMATION

App Name: Mountain Project

Package Name: com.mountainproject.android

Main Activity: com.mountainproject.android.activity.SplashActivity

Target SDK: 30

Min SDK: 17

Max SDK:

Android Version Name: 22.31.0

Android Version Code: 153

APP COMPONENTS

Activities: 7

Services: 13

Receivers: 7

Providers: 2

Exported Activities: 2

Exported Services: 1

Exported Receivers: 1

Exported Providers: 0

CERTIFICATE INFORMATION

APK is signed

v1 signature: True

v2 signature: True

v3 signature: True

Found 1 unique certificates

Subject: C=US, ST=ID, L=Victor, O=Watchout Software, OU=Watchout Software, CN=Sam Vanderhyden

Signature Algorithm: rsassa_pkcs1v15

Valid From: 2012-01-28 17:36:02+00:00

Valid To: 2039-06-15 17:36:02+00:00

Issuer: C=US, ST=ID, L=Victor, O=Watchout Software, OU=Watchout Software, CN=Sam Vanderhyden

Serial Number: 0x4f243202

Hash Algorithm: sha1

md5: dca4479e154f91b0886e9a39e3e303b7

sha1: e43f999d6ec3df52650412eaf643e3491083ebfb

sha256: a1a34c439d43882d5b3dcadac149225756ef55f945eca20e3b26be718254e36e

sha512: 987a1f10f08990471f694ae159b6f80a8645ffc6edeaca084faf49a11bbb94865d82df5d8765a211cfcc194c7105f8ccb96ba4a4f2ce137d7456ac97740ba942

PublicKey Algorithm: rsa

Bit Size: 2048

Fingerprint: df431b395d8318c9926d0a1cc12e8fd1617f3352058c1d5aacdee6afde878e66

APPLICATION PERMISSIONS

--	--	--	--

PERMISSION	STATUS	INFO	DESCRIPTION
android.permission.INTERNET	normal	full Internet access	Allows an application to create network sockets.
android.permission.ACCESS_NETWORK_STATE	normal	view network status	Allows an application to view the status of all networks.
android.permission.ACCESS_COARSE_LOCATION	dangerous	coarse (network-based) location	Access coarse location sources, such as the mobile network database, to determine an approximate phone location, where available. Malicious applications can use this to determine approximately where you are.
android.permission.ACCESS_FINE_LOCATION	dangerous	fine (GPS) location	Access fine location sources, such as the Global Positioning System on the phone, where available. Malicious applications can use this to determine where you are and may consume additional battery power.
android.permission.WRITE_EXTERNAL_STORAGE	dangerous	read/modify/delete external storage contents	Allows an application to write to external storage.
android.permission.WAKE_LOCK	normal	prevent phone from sleeping	Allows an application to prevent the phone from going to sleep.
android.permission.RECEIVE_BOOT_COMPLETED	normal	automatically start at boot	Allows an application to start itself as soon as the system has finished booting. This can make it take longer to start the phone and allow the application to slow down the overall phone by always running.
com.google.android.finsky.permission.BIND_GET_INSTALL_REFERRER_SERVICE	unknown	Unknown permission	Unknown permission from android reference
com.google.android.c2dm.permission.RECEIVE	signature	C2DM permissions	Permission for cloud to device messaging.

APKID ANALYSIS

FILE	DETAILS	
classes.dex	FINDINGS	DETAILS
	Anti-VM Code	Build.FINGERPRINT check Build.MODEL check Build.MANUFACTURER check Build.PRODUCT check Build.TAGS check network operator name check
	Anti Debug Code	Debug.isDebuggerConnected() check
	Compiler	r8

BROWSABLE ACTIVITIES

ACTIVITY	INTENT
com.mountainproject.android.activity.SplashActivity	Schemes: https://, Hosts: www.mountainproject.com, Path Prefixes: /route, /area,
com.facebook.CustomTabActivity	Schemes: fbconnect://, Hosts: cct.com.mountainproject.android,
com.google.android.gms.tagmanager.TagManagerPreviewActivity	Schemes: tagmanager.c.com.mountainproject.android://,

NETWORK SECURITY

NO	SCOPE	SEVERITY	DESCRIPTION
----	-------	----------	-------------

CERTIFICATE ANALYSIS

TITLE	SEVERITY	DESCRIPTION
Signed Application	info	Application is signed with a code signing certificate
Application vulnerable to Janus Vulnerability	warning	Application is signed with v1 signature scheme, making it vulnerable to Janus vulnerability on Android 5.0-8.0, if signed only with v1 signature scheme. Applications running on Android 5.0-7.0 signed with v1, and v2/v3 scheme is also vulnerable.
Certificate algorithm vulnerable to hash collision	high	Application is signed with SHA1withRSA. SHA1 hash algorithm is known to have collision issues.

MANIFEST ANALYSIS

NO	ISSUE	SEVERITY	DESCRIPTION
1	Clear text traffic is Enabled For App [android:usesCleartextTraffic=true]	high	The app intends to use cleartext network traffic, such as cleartext HTTP, FTP stacks, DownloadManager, and MediaPlayer. The default value for apps that target API level 27 or lower is "true". Apps that target API level 28 or higher default to "false". The key reason for avoiding cleartext traffic is the lack of confidentiality, authenticity, and protections against tampering; a network attacker can eavesdrop on transmitted data and also modify it without being detected.

2	Application Data can be Backed up [android:allowBackup=true]	warning	This flag allows anyone to backup your application data via adb. It allows users who have enabled USB debugging to copy application data off of the device.
3	Launch Mode of activity (com.mountainproject.android.activity.SplashActivity) is not standard.	high	An Activity should not be having the launch mode attribute set to "singleTask/singleInstance" as it becomes root Activity and it is possible for other applications to read the contents of the calling Intent. So it is required to use the "standard" launch mode attribute when sensitive information is included in an Intent.
4	Launch Mode of activity (com.mountainproject.android.activity.MainActivity) is not standard.	high	An Activity should not be having the launch mode attribute set to "singleTask/singleInstance" as it becomes root Activity and it is possible for other applications to read the contents of the calling Intent. So it is required to use the "standard" launch mode attribute when sensitive information is included in an Intent.
5	Service (com.evernote.android.job.gcm.PlatformGcmService) is Protected by a permission, but the protection level of the permission should be checked. Permission: com.google.android.gms.permission.BIND_NETWORK_TASK_SERVICE [android:exported=true]	warning	A Service is found to be shared with other apps on the device therefore leaving it accessible to any other application on the device. It is protected by a permission which is not defined in the analysed application. As a result, the protection level of the permission should be checked where it is defined. If it is set to normal or dangerous, a malicious application can request and obtain the permission and interact with the component. If it is set to signature, only applications signed with the same certificate can obtain the permission.
6	Broadcast Receiver (com.google.firebase.iid.FirebaseInstanceIdReceiver) is Protected by a permission, but the protection level of the permission should be checked. Permission: com.google.android.c2dm.permission.SEND [android:exported=true]	warning	A Broadcast Receiver is found to be shared with other apps on the device therefore leaving it accessible to any other application on the device. It is protected by a permission which is not defined in the analysed application. As a result, the protection level of the permission should be checked where it is defined. If it is set to normal or dangerous, a malicious application can request and obtain the permission and interact with the component. If it is set to signature, only applications signed with the same certificate can obtain the permission.

</> CODE ANALYSIS

--	--	--	--	--

NO	ISSUE	SEVERITY	STANDARDS	FILES
1	The App logs information. Sensitive information should never be logged.	info	CWE: CWE-532: Insertion of Sensitive Information into Log File OWASP MASVS: MSTG-STORAGE-3	com/afollestad/materialdialogs/internal/c.java com/aigestudio/wheelpicker/WheelPicker.java com/github/mikephil/charting/charts/BarChart.java com/github/mikephil/charting/charts/BarLineChartBase.java com/github/mikephil/charting/charts/Chart.java com/github/mikephil/charting/charts/CombinedChart.java com/github/mikephil/charting/charts/a.java com/github/mikephil/charting/data/i.java com/github/mikephil/charting/data/l.java com/github/mikephil/charting/listener/a.java com/github/mikephil/charting/renderer/l.java com/github/mikephil/charting/utils/e.java e/a/k/a/a.java e/a/o/g.java e/h/d/a.java e/h/d/c/a.java e/h/d/c/b.java e/h/d/c/f.java e/h/e/b.java e/h/e/d.java e/h/e/e.java e/h/e/f.java e/h/e/h.java e/h/e/i.java e/h/k/b.java e/j/b/a.java e/l/a/a.java e/m/a/b.java e/n/a.java e/n/c.java e/p/d0.java

				e/p/e0.java e/p/f0.java e/p/g0.java e/p/y.java e/p/z.java e/q/a/a/i.java f/a/a/a/a.java f/c/a/a/i/t/a.java f/c/a/c/b/c/g.java f/c/a/c/b/d/s.java f/c/a/c/c/b/a.java f/c/a/c/d/a.java f/c/a/d/j/h.java f/c/a/d/k/a.java l/a/a/b0.java l/a/a/i0/g.java me/zhanghai/android/materialprogressbar/BaseProgressLayerDrawable.java me/zhanghai/android/materialprogressbar/MaterialProgressBar.java org/greenrobot/eventbus/b.java org/greenrobot/eventbus/c.java
2	App can read/write to External Storage. Any App can read data written to External Storage.	warning	CWE: CWE-276: Incorrect Default Permissions OWASP Top 10: M2: Insecure Data Storage OWASP MASVS: MSTG-STORAGE-2	com/github/mikephil/charting/charts/Chart.java
3	App uses SQLite Database and execute raw SQL query. Untrusted user input in raw SQL queries can cause SQL Injection. Also sensitive information should be encrypted and written to the database.	warning	CWE: CWE-89: Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') OWASP Top 10: M7: Client Code Quality	com/evernote/android/job/k.java com/mountainproject/android/m/a.java f/c/a/a/i/v/j/b0.java f/c/a/a/i/v/j/f0.java f/c/a/a/i/v/j/h0.java
4	The App uses an insecure Random Number Generator.	warning	CWE: CWE-330: Use of Insufficiently Random Values OWASP Top 10: M5: Insufficient Cryptography OWASP MASVS: MSTG-CRYPTO-6	com/mountainproject/android/activity/f/a.java com/mountainproject/android/p/b.java
5	This App uses SSL certificate pinning to detect or prevent MITM attacks in	secure	OWASP MASVS: MSTG-NETWORK-1	m/h0/c.java

	secure communication channel.		OWASP MASVS: MSTG-NETWORK-4	
6	App creates temp file. Sensitive information should never be written into a temp file.	warning	CWE: CWE-276: Incorrect Default Permissions OWASP Top 10: M2: Insecure Data Storage OWASP MASVS: MSTG-STORAGE-2	com/mountainproject/android/o/a/e.java e/n/c.java

NIAP ANALYSIS v1.3

NO	IDENTIFIER	REQUIREMENT	FEATURE	DESCRIPTION
1	FCS_RBG_EXT.1.1	Security Functional Requirements	Random Bit Generation Services	The application invoke platform-provided DRBG functionality for its cryptographic operations.
2	FCS_STO_EXT.1.1	Security Functional Requirements	Storage of Credentials	The application does not store any credentials to non-volatile memory.
3	FCS_CKM_EXT.1.1	Security Functional Requirements	Cryptographic Key Generation Services	The application implement asymmetric key generation.
4	FDP_DEC_EXT.1.1	Security Functional Requirements	Access to Platform Resources	The application has access to ['network connectivity', 'location'].
5	FDP_DEC_EXT.1.2	Security Functional Requirements	Access to Platform Resources	The application has access to no sensitive information repositories.
6	FDP_NET_EXT.1.1	Security Functional Requirements	Network Communications	The application has user/application initiated network communications.
7	FDP_DAR_EXT.1.1	Security Functional Requirements	Encryption Of Sensitive Application Data	The application implement functionality to encrypt sensitive data in non-volatile memory.

8	FMT_MEC_EXT.1.1	Security Functional Requirements	Supported Configuration Mechanism	The application invoke the mechanisms recommended by the platform vendor for storing and setting configuration options.
9	FTP_DIT_EXT.1.1	Security Functional Requirements	Protection of Data in Transit	The application does encrypt some transmitted data with HTTPS/TLS/SSH between itself and another trusted IT product.
10	FCS_RBG_EXT.2.1,FCS_RBG_EXT.2.2	Selection-Based Security Functional Requirements	Random Bit Generation from Application	The application perform all deterministic random bit generation (DRBG) services in accordance with NIST Special Publication 800-90A using Hash_DRBG. The deterministic RBG is seeded by an entropy source that accumulates entropy from a platform-based DRBG and a software-based noise source, with a minimum of 256 bits of entropy at least equal to the greatest security strength (according to NIST SP 800-57) of the keys and hashes that it will generate.
11	FCS_CKM.1.1(1)	Selection-Based Security Functional Requirements	Cryptographic Asymmetric Key Generation	The application generate asymmetric cryptographic keys in accordance with a specified cryptographic key generation algorithm RSA schemes using cryptographic key sizes of 2048-bit or greater.
12	FCS_COP.1.1(2)	Selection-Based Security Functional Requirements	Cryptographic Operation - Hashing	The application perform cryptographic hashing services not in accordance with FCS_COP.1.1(2) and uses the cryptographic algorithm RC2/RC4/MD4/MD5.
13	FCS_HTTPS_EXT.1.1	Selection-Based Security Functional Requirements	HTTPS Protocol	The application implement the HTTPS protocol that complies with RFC 2818.
14	FCS_HTTPS_EXT.1.2	Selection-Based Security Functional Requirements	HTTPS Protocol	The application implement HTTPS using TLS.
15	FCS_HTTPS_EXT.1.3	Selection-Based Security Functional Requirements	HTTPS Protocol	The application notify the user and not establish the connection or request application authorization to establish the connection if the peer certificate is deemed invalid.
16	FIA_X509_EXT.2.1	Selection-Based Security Functional	X.509 Certificate	The application use X.509v3 certificates as defined by RFC 5280 to support

		Requirements	Authentication	authentication for HTTPS , TLS.
17	FPT_TUD_EXT.2.1	Selection-Based Security Functional Requirements	Integrity for Installation and Update	The application shall be distributed using the format of the platform-supported package manager.

DOMAIN MALWARE CHECK

DOMAIN	STATUS	GEOLOCATION
issuetracker.google.com	ok	IP: 142.250.189.238 Country: United States of America Region: California City: Mountain View Latitude: 37.405991 Longitude: -122.078514 View: Google Map
schemas.android.com	ok	No Geolocation information available.
www.trailrunproject.com	ok	IP: 34.120.248.240 Country: United States of America Region: Missouri City: Kansas City Latitude: 39.099731 Longitude: -94.578568 View: Google Map
www.mountainproject.com	ok	IP: 34.111.52.167 Country: United States of America Region: California City: Mountain View Latitude: 37.405991 Longitude: -122.078514 View: Google Map

main-stack-562.firebaseio.com	ok	IP: 34.120.160.131 Country: United States of America Region: Missouri City: Kansas City Latitude: 39.099731 Longitude: -94.578568 View: Google Map
github.com	ok	IP: 140.82.112.3 Country: United States of America Region: California City: San Francisco Latitude: 37.775700 Longitude: -122.395203 View: Google Map
www.mtbproject.com	ok	IP: 34.111.125.30 Country: United States of America Region: California City: Mountain View Latitude: 37.405991 Longitude: -122.078514 View: Google Map
www.powderproject.com	ok	IP: 35.201.101.186 Country: United States of America Region: Missouri City: Kansas City Latitude: 39.099731 Longitude: -94.578568 View: Google Map
www.adventureprojects.net	ok	IP: 35.244.231.149 Country: United States of America Region: Missouri City: Kansas City Latitude: 39.099731 Longitude: -94.578568

		View: Google Map
www.hikingproject.com	ok	IP: 35.227.218.124 Country: United States of America Region: Missouri City: Kansas City Latitude: 39.099731 Longitude: -94.578568 View: Google Map
realm.io	ok	IP: 99.84.238.216 Country: United States of America Region: California City: San Francisco Latitude: 37.774929 Longitude: -122.419418 View: Google Map
play.google.com	ok	IP: 142.251.32.46 Country: United States of America Region: California City: Mountain View Latitude: 37.405991 Longitude: -122.078514 View: Google Map

FIREBASE DATABASES

FIREBASE URL	DETAILS
https://main-stack-562.firebaseio.com	info App talks to a Firebase Database.

TRACKERS

TRACKER	CATEGORIES	URL
Facebook Login	Identification	https://reports.exodus-privacy.eu.org/trackers/67
Facebook Share		https://reports.exodus-privacy.eu.org/trackers/70
Google Analytics	Analytics	https://reports.exodus-privacy.eu.org/trackers/48
Google CrashLytics	Crash reporting	https://reports.exodus-privacy.eu.org/trackers/27
Google Firebase Analytics	Analytics	https://reports.exodus-privacy.eu.org/trackers/49
Google Tag Manager	Analytics	https://reports.exodus-privacy.eu.org/trackers/105

HARDCODED SECRETS

POSSIBLE SECRETS
"firebase_database_url" : "https://main-stack-562.firebaseio.com"
"gmaps_api_key" : "AlzaSyDAkyesSg3cN8P7hE2CkO1yqa1tfwDRw0"
"google_api_key" : "AlzaSyDAkyesSg3cN8P7hE2CkO1yqa1tfwDRw0"
"google_crash_reporting_api_key" : "AlzaSyDAkyesSg3cN8P7hE2CkO1yqa1tfwDRw0"

PLAYSTORE INFORMATION

Title: Mountain Project

Score: 4.5333333 Installs: 100,000+ Price: 0 Android Version Support: Category: Sports Play Store URL: [com.mountainproject.android](https://play.google.com/store/apps/details?id=com.mountainproject.android)

Developer Details: Adventure Projects, Adventure+Projects, None, <http://mountainproject.com>, support@mountainproject.com,

Release Date: May 15, 2013 Privacy Policy: [Privacy link](#)

Description:

Beyond the Guidebook: The Definitive Rock Climbing Resource. • Find outdoor climbing areas near you, and navigate to them, using the map. This super-handy new feature is one of our personal faves. • The much requested route finder: Easily sort routes by discipline, difficulty, star ranking and more. If a 4-star M9 is your thing, we'll help you find it. • Search our entire database of 155,000+ climbing routes, even offline. • Download route beta, photos, and topos state by state for offline use — because the best crags often have the worst reception. • View a climbing area's route stats (how many 5.11s are there?) and critical info (when is the raptor closure again?) in a single glance. • Chat, ask questions, or put out a call for partners in our forum. • Rate routes and photos, keep track of attempts & sends, or make a to-do list • It's free to download and free of advertising too. Everything you need, nothing you don't. Links: • Privacy Policy: <https://www.adventureprojects.net/ap-privacy> • Terms of Service: <https://www.adventureprojects.net/ap-terms>

Report Generated by - MobSF v3.6.2 Beta

Mobile Security Framework (MobSF) is an automated, all-in-one mobile application (Android/iOS/Windows) pen-testing, malware analysis and security assessment framework capable of performing static and dynamic analysis.

© 2023 Mobile Security Framework - MobSF | [Ajin Abraham](#) | [OpenSecurity](#).